

Third-Party Risk Management Policy

MedCore Health

Document Owner: Nicholas Obuekwe

Effective Date: 6/16

Review Frequency: Annual, or sooner if business, regulatory, or risk conditions change

1. Purpose and Scope

The purpose of this Third-Party Risk Management policy is to establish a consistent process for identifying, assessing, monitoring, and managing risks introduced by third-party vendors, suppliers, contractors, service providers, and business partners that support MedCore Health operations. As a healthcare SaaS organization that processes patient data, MedCore Health must ensure that vendors handling sensitive information maintain appropriate security, privacy, compliance, and operational controls.

This policy exists to reduce the likelihood of unauthorized access, data loss, service disruption, regulatory noncompliance, and reputational harm caused by third-party relationships. Vendor risk is especially important for MedCore Health because third parties may process, store, transmit, or support systems containing Protected Health Information, Personally Identifiable Information, payment data, confidential business data, or internal operational information.

This policy applies to all MedCore Health employees, departments, and business units involved in selecting, onboarding, managing, renewing, or terminating vendor relationships. It also applies to all third-party vendors that provide technology services, cloud hosting, payment processing, communication tools, customer relationship management platforms, e-signature services, consulting support, or any other service that may impact MedCore Health's data, systems, customers, or business operations.

Examples of in-scope vendors include CloudHost Inc., CRM Pro, CollabTools, VideoMeet, DocSign Co., and PayProcess Ltd. These vendors support core business functions such as cloud infrastructure, customer relationship management, internal communications, video conferencing, e-signatures, and payment processing.

2. Vendor Classification Criteria

MedCore Health classifies vendors into four risk tiers: Critical, High, Medium, and Low. Vendor classification is based on the type of data accessed, the business criticality of the service, regulatory impact, integration with MedCore Health systems, and potential impact if the vendor experiences a security incident, outage, or compliance failure.

A vendor is classified as **Critical** when the vendor supports essential business operations, processes or stores Protected Health Information or highly sensitive data, has privileged access to production systems, or could cause significant business disruption if unavailable. Critical vendors require the highest level of

due diligence, executive visibility, and recurring monitoring. For example, a cloud infrastructure provider that hosts applications containing PHI and PII would be considered Critical.

A vendor is classified as **High** when the vendor processes sensitive data such as PII, PCI data, financial data, or customer information, but does not fully support the core infrastructure of MedCore Health. High-risk vendors may still create significant privacy, security, or compliance exposure if their controls are weak. Examples include customer relationship management platforms and payment processors.

A vendor is classified as **Medium** when the vendor has access to internal business data, contract data, limited confidential information, or provides services that support business operations but are not considered mission-critical. Medium-risk vendors may include e-signature platforms or internal collaboration tools where the impact of a compromise would be meaningful but not catastrophic.

A vendor is classified as **Low** when the vendor has minimal access to sensitive information, does not process regulated data, and does not support critical business operations. Low-risk vendors may include tools used for general communication, scheduling, or basic administrative support where disruption or compromise would have limited impact.

The following criteria should be reviewed during vendor classification:

- Data accessed: PHI, PII, PCI, confidential, internal-only, or public data
- Business criticality: whether the service is required for core operations
- System access: whether the vendor has access to production, administrative, or privileged systems
- Compliance impact: whether HIPAA, PCI DSS, SOC 2, ISO 27001, or other regulatory expectations apply
- Operational dependency: whether MedCore Health can continue operations if the vendor is unavailable
- Security maturity: whether the vendor maintains formal security certifications and documented controls

Vendor risk tiers must be recorded in the Vendor Inventory and reviewed before onboarding, during contract renewal, and after major changes to the vendor's service, data access, or security posture.

3. Due Diligence Requirements

Before onboarding any vendor, MedCore Health must complete a level of due diligence that matches the vendor's risk tier. Due diligence helps confirm that vendors maintain appropriate safeguards before they are allowed to access MedCore Health data, systems, or business processes.

For Critical and High vendors, MedCore Health requires a full vendor risk assessment before contract approval. This assessment must include a completed security questionnaire, review of independent audit reports or certifications, evidence of security controls, and review of legal and compliance requirements. Vendors that process PHI must also sign a Business Associate Agreement when applicable.

Required due diligence artifacts may include:

- Completed vendor security questionnaire
- SOC 2 Type II report, ISO 27001 certificate, PCI DSS Attestation of Compliance, or equivalent evidence
- HIPAA Business Associate Agreement, when applicable
- Data processing agreement, privacy addendum, or contractual security terms
- Incident response and breach notification procedures
- Business continuity and disaster recovery documentation
- Evidence of encryption at rest and in transit
- Access control and MFA documentation
- Subprocessor list, if the vendor uses additional third parties
- Penetration testing summary or vulnerability management evidence, where available

For Medium vendors, MedCore Health may require an abbreviated questionnaire and targeted evidence review based on the type of data accessed. For Low vendors, a basic self-attestation or limited review may be sufficient if the vendor does not access regulated or sensitive information.

Vendors with incomplete due diligence, missing evidence, or significant control gaps may not be approved until the risk is reviewed and accepted by the appropriate business owner and GRC team. If the vendor is necessary for business operations, MedCore Health may approve the vendor conditionally with a documented risk treatment plan, remediation timeline, and assigned risk owner.

4. Ongoing Monitoring

Vendor risk management does not end after onboarding. MedCore Health must reassess vendors periodically to confirm that their security, compliance, and operational controls remain effective over time. Ongoing monitoring helps identify changes in vendor risk, such as expired certifications, new subprocessors, control failures, security incidents, service disruptions, or changes in data access.

MedCore Health uses a tiered review schedule based on vendor risk:

- Critical vendors: reviewed annually and after any significant security incident, material service change, or major contract change
- High vendors: reviewed annually
- Medium vendors: reviewed every two years
- Low vendors: reviewed every three years using self-attestation or limited review

Critical vendors require the most frequent monitoring because they support essential operations or process the most sensitive data. High vendors require annual review because they may process sensitive customer, payment, or business data. Medium and Low vendors are reviewed less frequently because their access and operational impact are more limited.

Ongoing monitoring activities may include reviewing updated SOC 2 reports, confirming insurance or compliance status, checking for changes in data processing, reviewing vendor security advisories, validating remediation of prior findings, and confirming whether the vendor has experienced any reportable incidents.

If a vendor's risk profile changes, MedCore Health may update the vendor's risk tier. For example, a Medium vendor may become High if the vendor begins processing PII or becomes integrated with a production system. Similarly, a High vendor may become Critical if the vendor becomes essential to business continuity or begins hosting PHI.

5. Incident Notification Requirements

All vendors must notify MedCore Health promptly if they experience an actual or suspected security incident that may impact MedCore Health data, systems, customers, operations, or regulatory obligations. This includes unauthorized access, data disclosure, ransomware, malware, credential compromise, service disruption, insider misuse, loss of data, or compromise of any system used to process MedCore Health information.

Vendors must provide initial notification as soon as possible and no later than the timeframe required by contract, regulation, or applicable law. For vendors that process PHI, notification requirements must align with HIPAA obligations and any Business Associate Agreement terms.

At minimum, vendor incident notifications must include:

- Date and time the incident was discovered
- Description of what happened
- Systems, services, or data impacted
- Whether MedCore Health data was accessed, disclosed, altered, or unavailable
- Known or suspected root cause
- Actions taken to contain and investigate the incident
- Timeline for remediation and recovery
- Contact information for the vendor's incident response lead
- Any regulatory, customer, or law enforcement notifications already made or planned

MedCore Health reserves the right to request additional information, require remediation evidence, conduct a risk review, suspend vendor access, or terminate the relationship depending on the severity of the incident. Vendors must cooperate with MedCore Health's investigation, legal review, customer notification process, and regulatory response activities.

6. Vendor Offboarding

When a vendor relationship ends, MedCore Health must ensure that access is removed, data is returned or securely destroyed, contractual obligations are closed, and business continuity risks are addressed. Vendor offboarding must be performed in a controlled manner to prevent unauthorized access, data retention issues, service disruption, or compliance gaps.

The business owner is responsible for notifying the GRC, Legal, IT, Security, and Procurement teams when a vendor relationship is ending. The offboarding process must include confirmation that all vendor user accounts, API keys, integrations, administrative access, remote access, and shared credentials are disabled or removed.

Vendor offboarding requirements include:

- Termination of system access and integrations
- Confirmation that MedCore Health data has been returned, deleted, or securely destroyed
- Written data deletion or destruction attestation, when applicable
- Removal of vendor accounts from internal systems
- Review of outstanding invoices, contract terms, and renewal obligations
- Transfer of critical documentation, data, or operational knowledge
- Validation that replacement services or contingency plans are in place
- Closure of open risk treatment items or documentation of residual risk

For vendors that processed PHI, PII, PCI, or confidential data, MedCore Health must obtain written confirmation that data has been handled according to contractual, regulatory, and security requirements. If the vendor is unable to provide sufficient evidence of data deletion or return, the issue must be escalated to Legal, Security, and the GRC team for risk review.

7. Policy Owner and Review Frequency

The Governance, Risk, and Compliance team owns this policy and is responsible for maintaining the Third-Party Risk Management program. The GRC team coordinates with Security, Legal, Procurement, Privacy, IT, and business owners to ensure vendors are assessed, classified, monitored, and offboarded according to this policy.

This policy must be reviewed at least annually. It must also be reviewed when there are significant changes to MedCore Health's business model, regulatory requirements, vendor environment, security strategy, or risk appetite. Updates may also be required after a major vendor incident, audit finding, compliance gap, or change in applicable laws or industry standards.

All exceptions to this policy must be documented, risk-ranked, approved by the appropriate business and risk owners, and reviewed periodically until resolved or formally accepted.